Helix Patient Portal security review

1. Authentication

Staff authenticate with Azure AD single sign-on. Patients use email and a one-time code.

Sessions expire after 15 minutes of inactivity, as required by Helix policy (HLX-105).

2. Data protection

Patient records are encrypted at rest with AES-256 and in transit with TLS 1.2 or higher.

3. Audit and compliance

Every change to roles or permissions is written to an append-only audit log (HLX-102).

Audit logs are retained for 7 years and reviewed by Helix compliance every quarter.

4. Open findings

Finding SR-3: password policy screen must enforce 12 character minimum (HLX-110). Due before go-live.